

Scenario – Attacco informatico e sicurezza compromessa

Durante la notte, il sistema di monitoraggio dell'infrastruttura IT segnala un accesso anomalo proveniente da un IP estero. Alcuni file interni risultano copiati, e l'accesso a una cartella contenente dati sensibili dei clienti è stato registrato per oltre 30 minuti senza autorizzazione. L'evento è avvenuto su un server cloud non aggiornato. Al momento, non ci sono conferme ufficiali di esfiltrazione, ma il rischio è alto.

Il CEO convoca immediatamente un tavolo di crisi. Ogni figura deve:

1. Analizzare la situazione dal proprio punto di vista
2. Raccogliere informazioni e formulare una proposta
3. Collaborare con gli altri per definire una risposta strategica condivisa

Dati e criticità note:

- **Data e ora accesso sospetto:** 02:17, notte tra sabato e domenica
- **IP tracciato:** localizzazione extra-UE
- **File coinvolti:** report vendite e archivio clienti
- **Durata accesso:** 37 minuti continuativi
- **Server coinvolto:** backup cloud secondario, aggiornamenti sospesi da 3 mesi
- **Software antivirus e IDS attivi, ma non configurati correttamente**
- **Ancora nessuna comunicazione esterna o conferma fuga dati**

Ruoli coinvolti:

1. Responsabile Cyber Security

- Verificare natura e portata dell'attacco
- Identificare vulnerabilità sfruttate
- Proporre misure immediate di contenimento e audit interno

2. CTO (Responsabile tecnico)

- Controllare i log e lo stato dei server
- Coordinare ripristino e aggiornamenti
- Valutare responsabilità nei ritardi di manutenzione

3. Responsabile Legale/Privacy

- Valutare impatti GDPR e obblighi di notifica al Garante
- Redigere comunicazione per stakeholder e clienti (se necessaria)

4. Responsabile Comunicazione/Marketing

- Preparare un piano di comunicazione di crisi
- Gestire l'impatto reputazionale sull'immagine aziendale

5. CEO (Direttore Generale)

- Prendere decisioni strategiche e mediare tra esigenze tecniche, legali e commerciali
- Decidere se e quando comunicare pubblicamente l'accaduto

Glossario sintetico (per lo Scenario – Cyber Security)

Accesso anomalo: attività sospetta su un sistema informatico, proveniente da un luogo o utente insolito, che può indicare un tentativo di intrusione.

IP estero: indirizzo identificativo di un dispositivo connesso a internet situato fuori dall'Unione Europea. Può indicare un attacco proveniente dall'estero.

Esfiltrazione di dati: furto o copia non autorizzata di dati da un sistema informatico verso l'esterno.

Server cloud: computer remoto utilizzato per archiviare e gestire dati e applicazioni. Se non aggiornato può essere vulnerabile.

Antivirus: software che rileva e blocca programmi dannosi (virus, malware). Va aggiornato regolarmente.

IDS (Intrusion Detection System): sistema che monitora e segnala accessi non autorizzati alla rete o ai dati aziendali.

Audit interno: analisi dettagliata dei sistemi per capire cosa è successo e individuare eventuali falle o errori.

GDPR: Regolamento Europeo sulla protezione dei dati personali. Impone l'obbligo di notifica al Garante in caso di violazione di dati sensibili.

Notifica al Garante: comunicazione formale che un'azienda deve fare entro 72 ore se ci sono state violazioni dei dati personali.

Comunicazione di crisi: messaggio ufficiale usato per informare clienti, stampa e stakeholder in caso di incidenti aziendali gravi.

Ripristino: operazione per riportare i sistemi alla normalità dopo un malfunzionamento o attacco.